

网络安全

理论课程

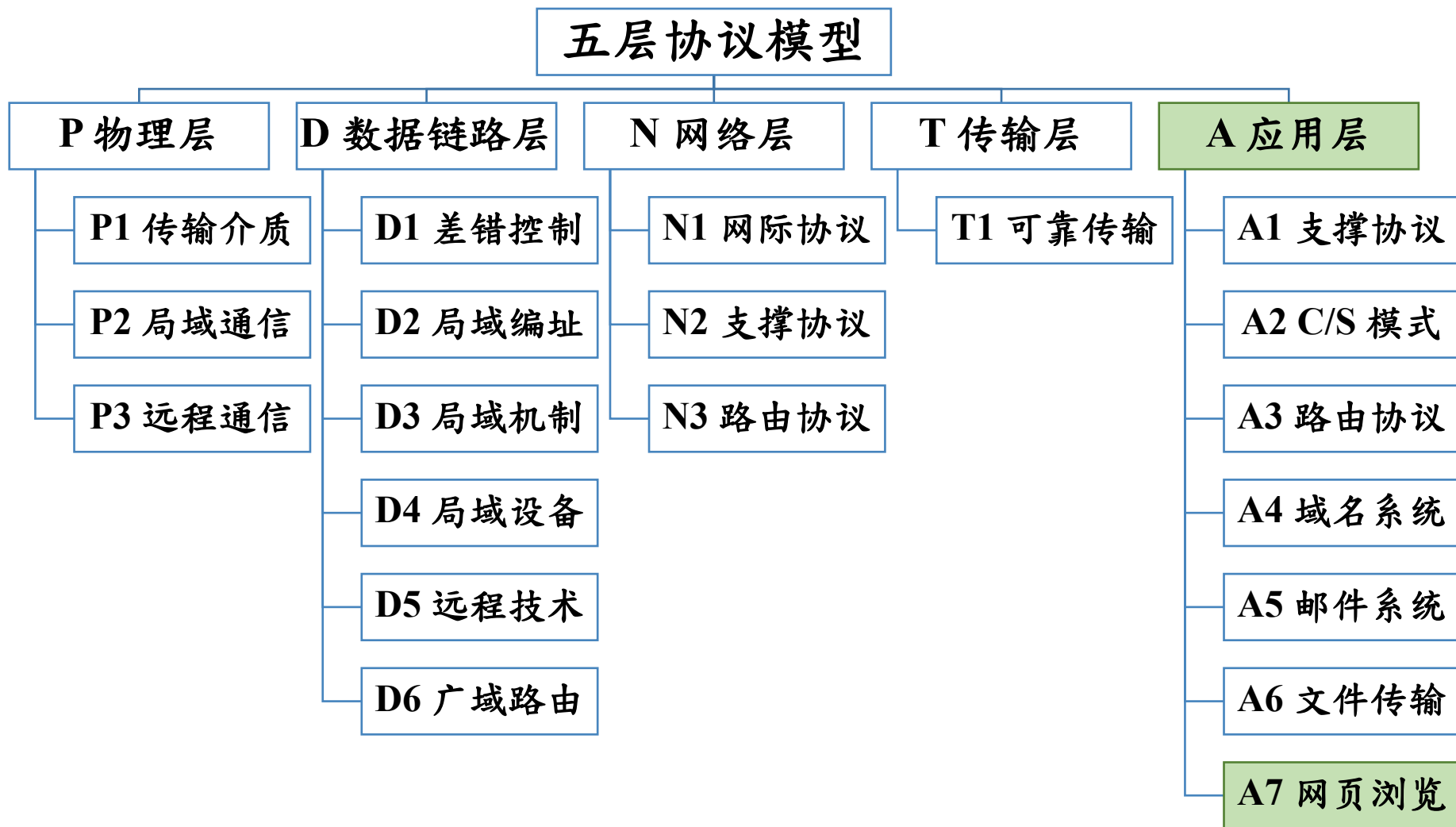


廈門大學
XIAMEN UNIVERSITY



信息学院 黃 煒
(特色化示范性软件学院) 博士, 副教授
School of Informatics Wei Huang

知识框架



主要内容

- 网络安全问题概述
- 两类密码体制
- 数字签名
- 鉴别
- 密钥分配
- 互联网使用的安全协议
- 系统安全：防火墙与入侵检测
- 一些未来的发展方向

对应课本章节

- 谢希仁课本，第7章 网络安全

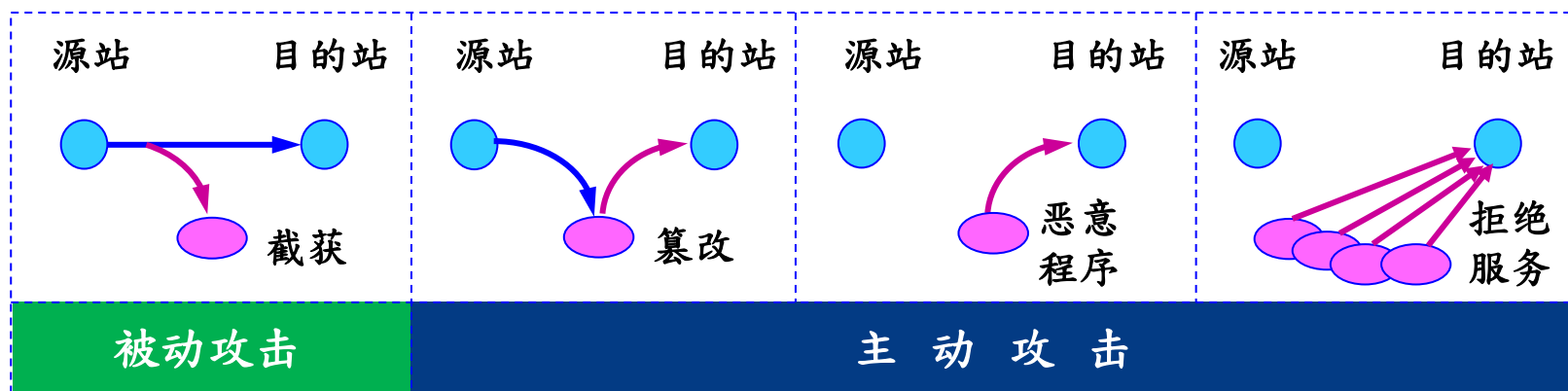


内容纲要

1	网络安全问题概述
2	两类密码体制
3	数字签名
4	鉴别
5	密钥分配

安全性威胁

- 计算机网络上的通信面临威胁：被动攻击和主动攻击。
- 被动攻击：攻击者从网络上窃听他人的通信内容。
 - 攻击者只是观察和分析某一个协议数据单元 PDU，以便了解所交换的数据的某种性质，但不干扰信息流。
 - 又称为截获、流量分析 (traffic analysis)。



安全性威胁

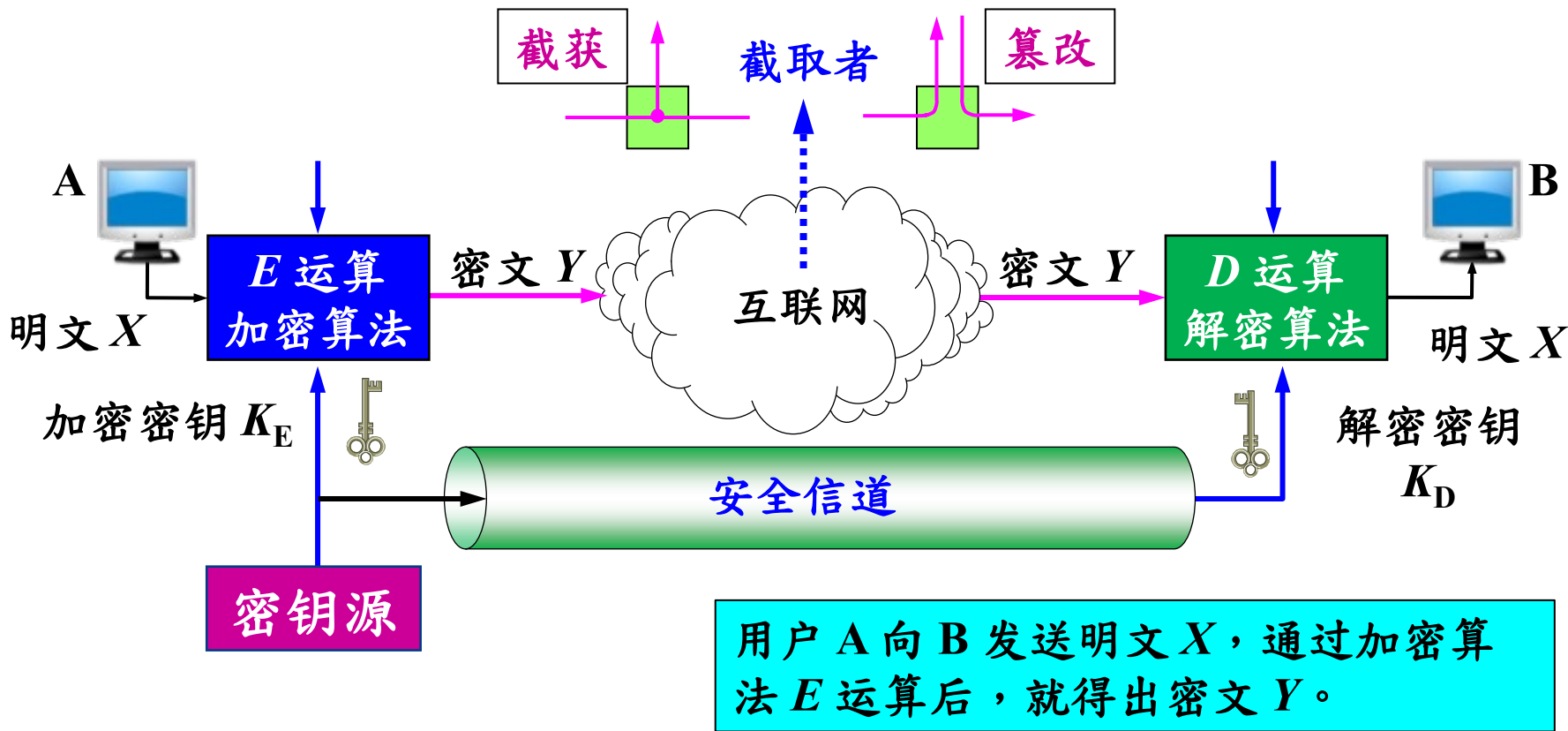
- 主动攻击

- 篡改：故意篡改网络上传送的报文。又称为更改报文流。
- 恶意程序：包括计算机病毒、计算机蠕虫、特洛伊木马、逻辑炸弹、后门入侵、流氓软件等。
- 拒绝服务：攻击者向互联网上的某个服务器发送大量分组，使该服务器无法提供正常服务，甚至完全瘫痪。
 - 从互联网上的成百上千的网站集中攻击一个网站，则称为分布式拒绝服务 DDoS，称为网络带宽攻击或连通性攻击。

安全的计算机网络

- 网络安全性是不可判定的，安全的网络四个目标：
 - 保密性：只有信息的收发双方懂得信息的内容。
 - 端点鉴别：鉴别收发双方的真实身份，对付主动攻击。
 - 信息的完整性：信息的内容未被篡改过。
 - 在谈到鉴别时，也同时包含了端点鉴别和报文完整性。
 - 运行的安全性：系统能正常运行并提供服务。
 - 访问控制（access control）对计算机系统的安全性是非常重要的。
必须对访问网络的权限加以控制，并规定每个用户的访问权限。

数据加密模型



密钥

- 明文通过加密算法 E 和加密密钥 K 变成密文：

$$Y = E_K(X)$$

- 密钥 K (key) 是一串秘密的字节串。
- 接收端用解密算法 D 运算和解密密钥 K 解出明文 X 。

$$D_K(Y) = D_K(E_K(X)) = X$$

- 解密算法是加密算法的逆运算。
- 密钥通常由密钥中心提供。
 - 加密密钥和解密密钥可以一样，也可以不一样。
 - 当密钥需要向远地传送时，一定要通过另一个安全信道。

一些重要概念

- 密码编码学 (cryptography) 是密码体制的设计学。
- 密码分析学 (cryptanalysis) 则是在未知密钥的情况下从密文推演出明文或密钥的技术。
- 密码编码学与密码分析学统称密码学 (cryptology)。
- 如果不论截取者获得了多少密文，但在密文中都没有足够的信息来唯一地确定出对应的明文，则这一密码体制称为无条件安全的，或称为理论上是不可破的。
- 如果密码体制中的密码不能被可使用的计算资源破译，则这一密码体制称为在计算上是安全的。

一些重要概念

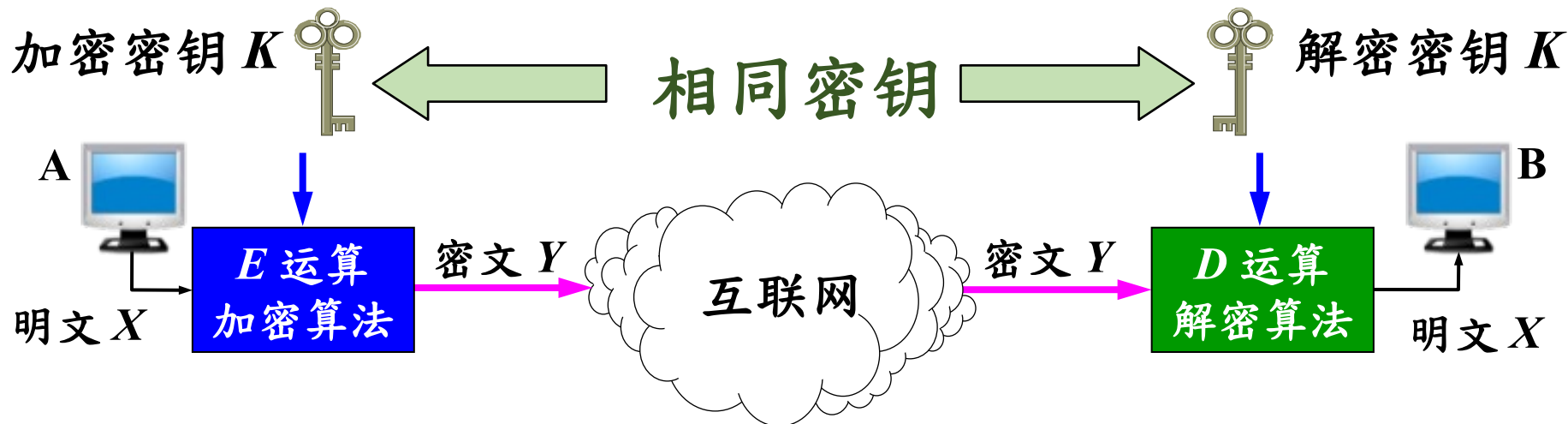
- 算法是公开的，通信保密性仅取决于对密钥的保密

内容纲要

1	网络安全问题概述
2	两类密码体制
3	数字签名
4	鉴别
5	密钥分配

对称密钥密码体制

- 常规密钥密码体制，加密密钥与解密密钥是相同。



- 数据加密标准 DES

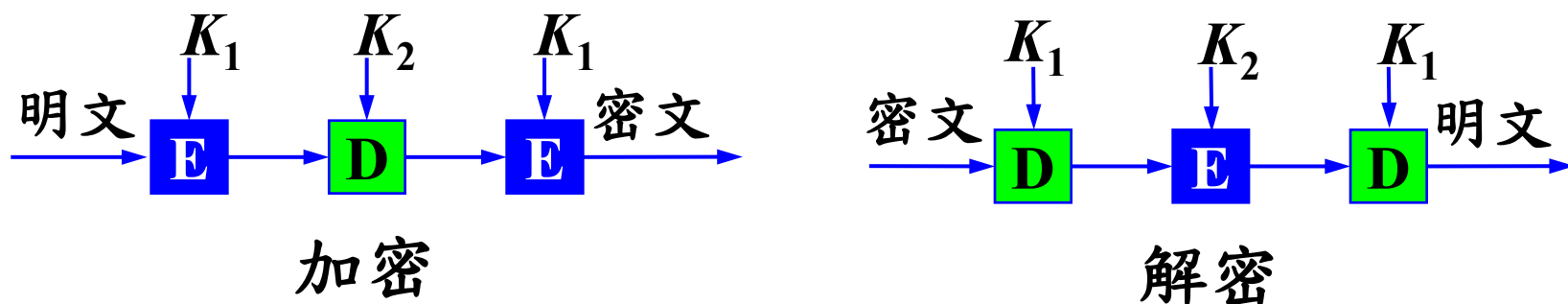
- 对整个明文进行 64 位分组，每组加密处理，再串接起来。
- 使用的密钥为 64 位：实际密钥 56 位，8 位奇偶校验。
 - DES 的密钥的长度太短，导致 DES 不是安全的。

对称密钥密码体制

• 三重 DES

- 使用两个 56 位的密钥。
- 把一个 64 位明文用一个密钥加密，再用另一个密钥解密，然后再使用第一个密钥加密。

$$Y = DES_{K_1}(DES^{-1}_{K_2}(DES_{K_1}(X)))$$



加密密钥与解密密钥

- 公钥密码体制中，需要
 - 加密密钥 PK (public key , 即公钥) 是向公众公开的
 - 解密密钥 SK (secret key , 即私钥或秘钥) 则是保密的
 - 加密算法 E 和解密算法 D 也都是公开的。
 - 不能根据 PK 计算出 SK 。
- 目前公钥加密开销较大，传统的加密方法仍有意义。
- 加密方法的安全性取决于密钥的长度，以及攻破密文所需的计算量。
- 需要密钥分配协议，过程并不比采用传统加密更简单。

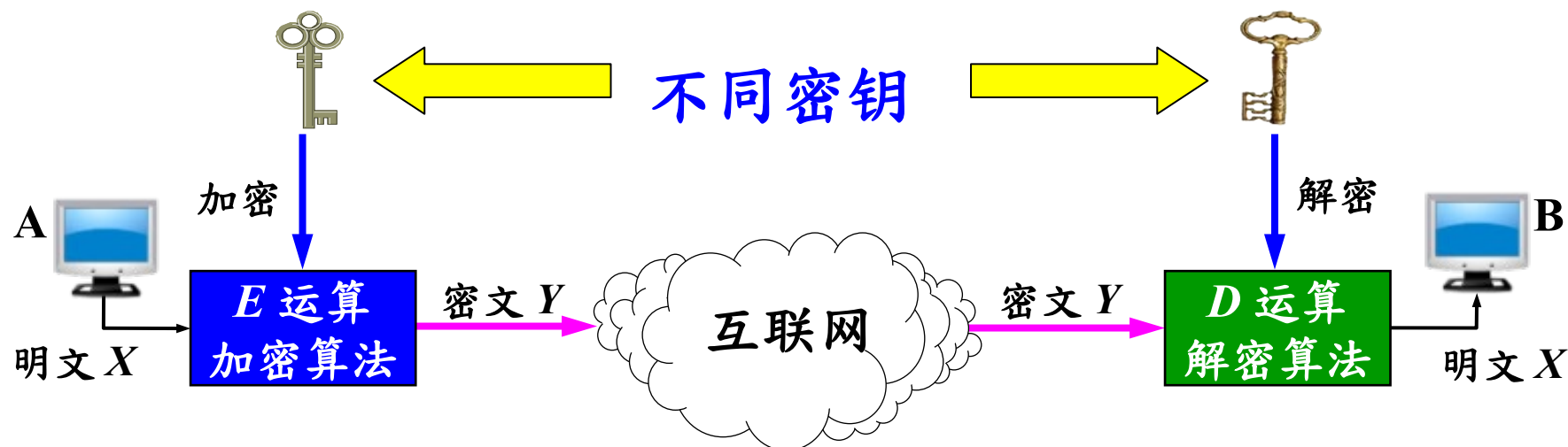
公钥算法的特点

- 密钥对产生器产生接收者 B 的公钥 PK_B 和私钥 SK_B 。
 - 公钥 PK_B 公开，通信时用于加密。
 - 私钥 SK_B 保密，通信时用于解密。

$$Y = E_{PK_B}(X), \quad X = D_{SK_B}(Y), \quad X \neq D_{PK_B}(Y)$$

B 的公钥 PK_B

B 的私钥 SK_B



公开密钥与对称密钥的区别

- 在使用对称密钥时，由于双方使用同样的密钥，因此在通信信道上可以进行**一对一的双向保密通信**，每一方既可用此密钥加密明文，并发送给对方，也可接收密文，用同一密钥对密文解密。这种保密通信仅限于持有此密钥的双方（如再有第三方就不保密了）。
- 在使用公开密钥时，在通信信道上可以是**多对一的单向保密通信**。

公钥密码体制

- 保密

- 某一信息用公开密钥加密，必须用私有密钥解密

- 数字签名

- 某一信息用私有密钥加密，必须用公开密钥解密。

内容纲要

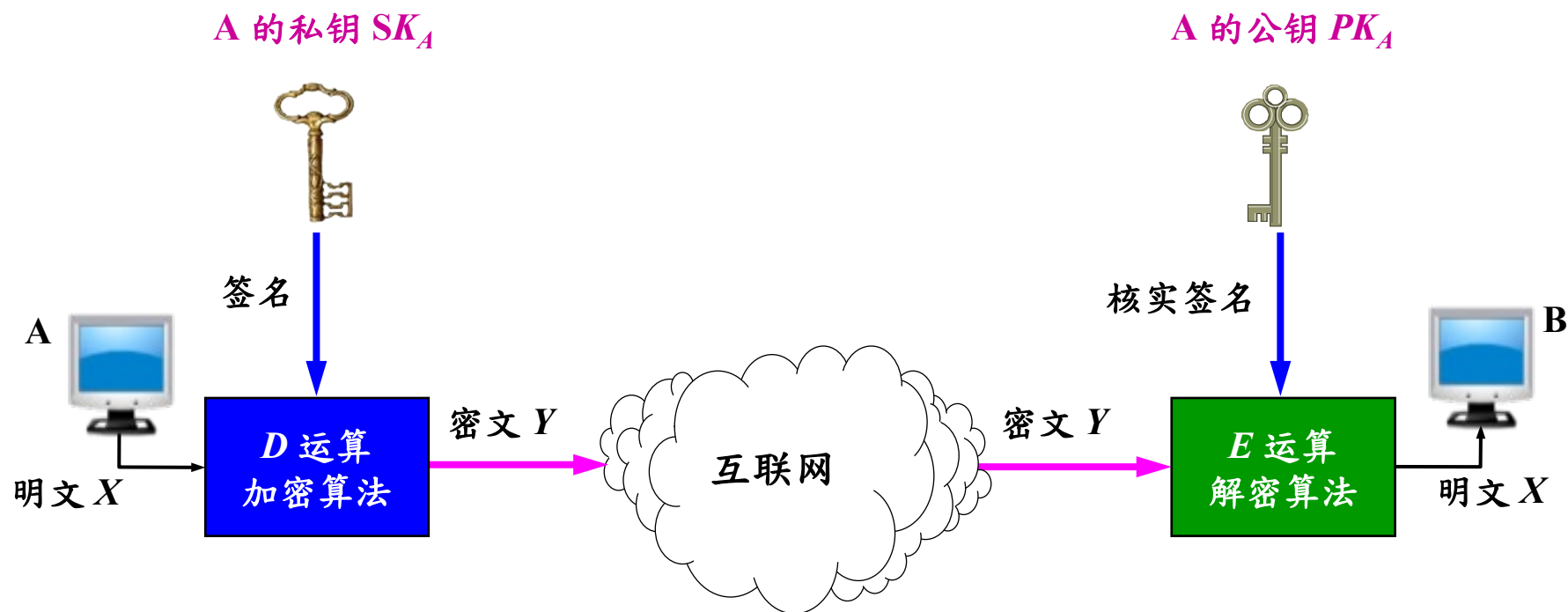
1	网络安全问题概述
2	两类密码体制
3	数字签名
4	鉴别
5	密钥分配

数字签名

- 用于证明真实性。
- 数字签名必须保证以下三点：
 - 报文鉴别——接收者能够核实发送者对报文的签名（证明来源）；
 - 报文的完整性——发送者事后不能抵赖对报文的签名（防否认）；
 - 不可否认——接收者不能伪造对报文的签名（防伪造）。
- 现在已有多种实现各种数字签名的方法。但采用公钥算法更容易实现。

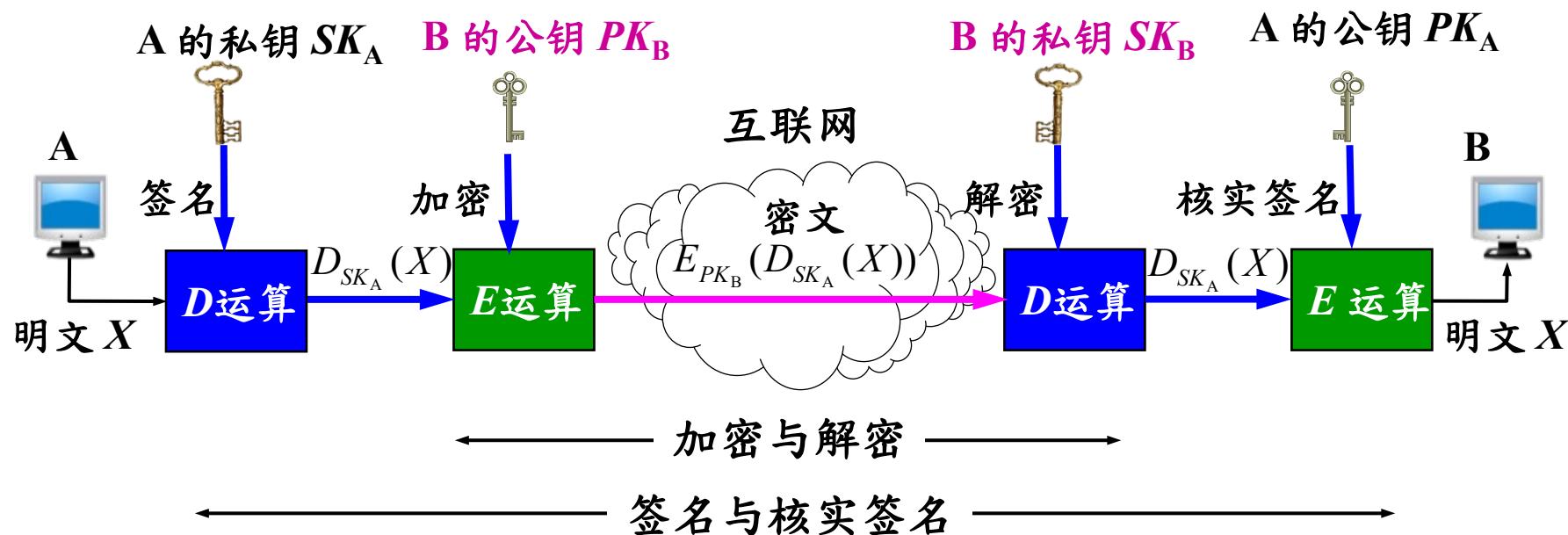
基于公钥的数字签名的实现

- 只有A持有私钥 SK_A ，B无法伪造签名，A无法抵赖



具有保密性的数字签名

同时实现秘密通信和数字签名



内容纲要

2	两类密码体制
3	数字签名
4	鉴别
5	密钥分配
6	互联网使用的安全协议

鉴别

- 在信息的安全领域中，对付被动攻击的重要措施是加密，而对付主动攻击中的篡改和伪造则要用鉴别 (authentication)。
- 报文鉴别使得通信的接收方能够验证所收到的报文（发送者和报文内容、发送时间、序列等）的真伪。
- 使用加密就可达到报文鉴别的目的。但在网络的应用中，许多报文并不需要加密。应当使接收者能用很简单的方法鉴别报文的真伪。

鉴别

- 鉴别与授权 (authorization) 是不同的概念。
 - 授权：所进行的过程是否被允许（如是否可以写某文件）。
- 可再把鉴别细分为两种。
 - 报文鉴别：即鉴别所收到的报文的确是报文的发送者所发送的，而不是其他人伪造的或篡改的。这就包含了端点鉴别和报文完整性的鉴别。
 - 实体鉴别：仅仅鉴别发送报文的实体。实体可以是一个人，也可以是一个进程（客户或服务器）。这就是端点鉴别。

报文鉴别

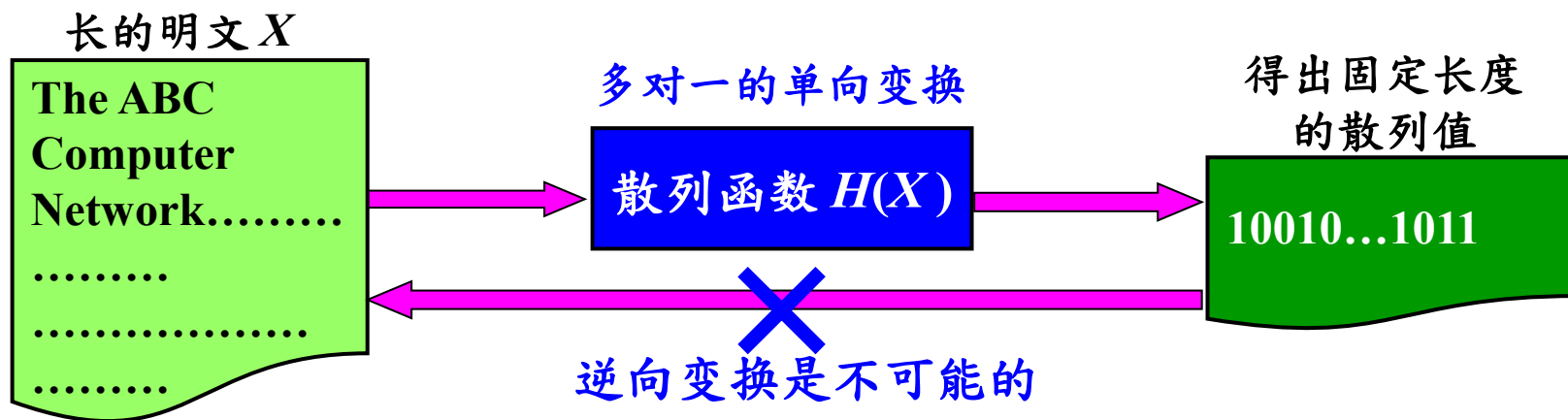
- 许多报文并不需要加密，但却需要数字签名，以便让报文的接收者能够鉴别报文的真伪。
- 然而对很长的报文进行数字签名会使计算机增加很大的负担（需要进行很长时间的运算）。
- 当我们传送不需要加密的报文时，应当使接收者能用很简单的方法鉴别报文的真伪。

密码散列函数

- 数字签名就能够实现对报文的鉴别。
 - 缺点：对较长的报文进行数字签名会使计算机增加非常大的负担，因为这需要较多的时间来进行运算。
- 密码散列函数 (cryptographic hash function) 是一种相对简单的对报文进行鉴别的方法。
- 散列函数的两个特点
 - 散列函数的输入长度可以很长，但其输出长度则是固定的，并且较短。散列函数的输出叫做散列值。
 - 不同的散列值肯定对应于不同的输入，但不同的输入却可能得出相同的散列值。这就是说，散列函数的输入和输出

密码散列函数的特点

- 在密码学中使用的散列函数称为密码散列函数。
- 特点：单向性。
 - 要找到两个不同的报文，它们具有同样的密码散列函数输出，在计算上是不可行的。
 - 密码散列函数实际上是一种单向函数 (one-way function)。



散列 $H(X)$ 可用来保护明文 X 的完整性，防篡改和伪造。

实用的密码散列函数

- 通过许多学者的不断努力，已经设计出一些实用的密码散列函数（或称为散列算法），其中最出名的就是 MD5 和 SHA-1。
- 报文摘要算法 MD5 公布于 RFC 1321 (1991年)，并获得了非常广泛的应用。
- SHA-1 比 MD5 更安全，但计算起来却比 MD5 要慢些。

MD5 算法

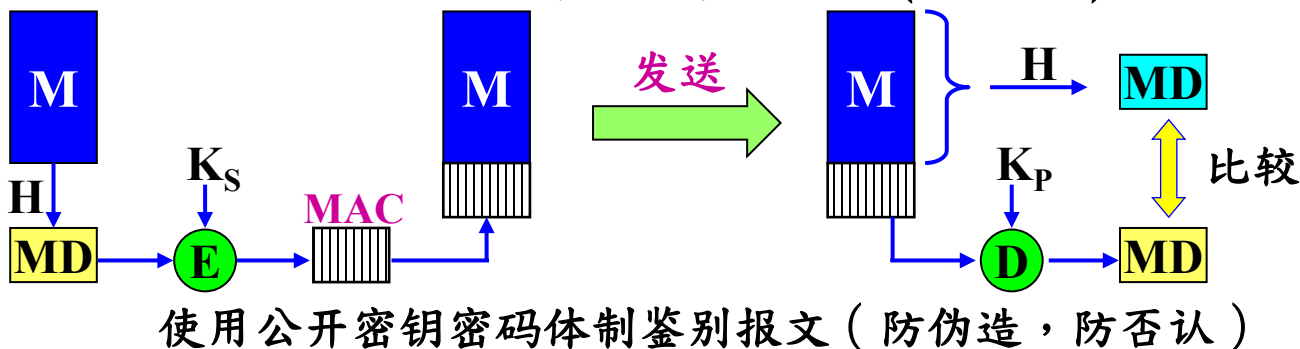
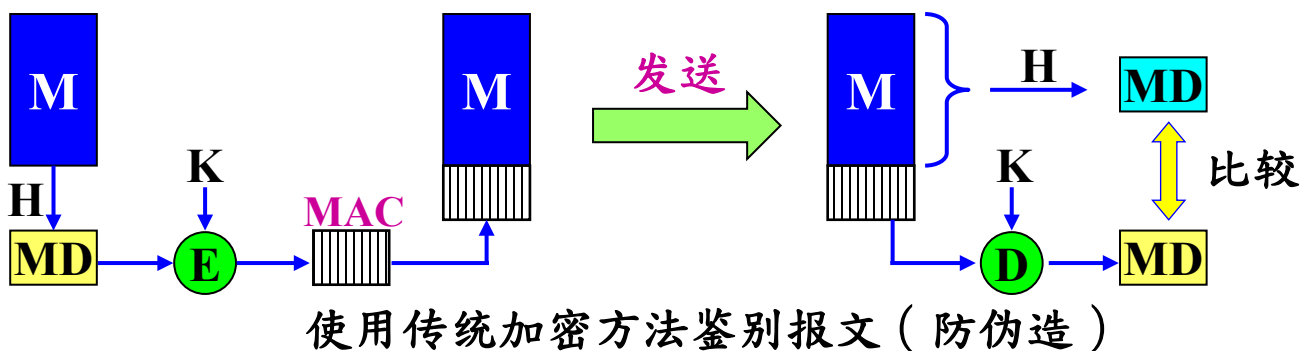
- 附加：把任意长的报文按模 264 计算其余数（64位），追加在报文的后面（长度项）。
- 填充：在报文和长度项之间填充至总长度是 512 的整数倍。填充的首位是 1，后面都是 0。
- 分组：把填充后的报文分割为 512 位的数据块，每个 512 位的报文数据再分成 4 个 128 位的数据块。
- 计算：将 4 个 128 位的数据块依次送到不同的散列函数进行 4 轮计算。每轮按 32 位的小数据块进行运算。
- 直到最后算出 MD5 报文摘要代码（128 位）。

SHA-1

- 安全散列算法 SHA (Secure Hash Algorithm)是由美国标准与技术协会 NIST 提出的一个散列算法系列。
- SHA 比 MD5 更安全，但计算起来却比 MD5 要慢些。
- 已制定 SHA-1、SHA-2、SHA-3 等版本。
- SHA-1算法
 - 要求输入码长小于 264 位，输出码长为 160 位。
 - 将明文分成若干 512 位的定长块，每一块与当前的报文摘要值结合，产生摘要的下一个中间结果，直到处理完毕。
 - 共扫描 5 遍，效率略低于 MD5，抗穷举性更高。

报文鉴别

- 对散列进行加密，实现报文鉴别
 - 结果叫做报文鉴别码 MAC (Message Authentication Code)
 - 散列 H 的长度通常远小于报文 X 的长度，计算耗费不大。

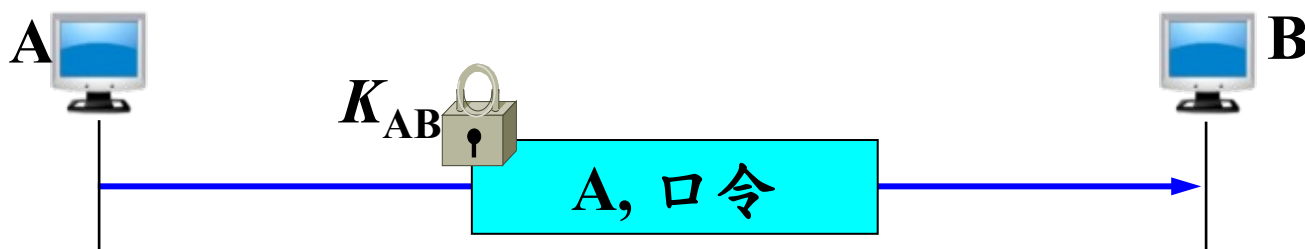


实体鉴别

- 报文鉴别是对每一个收到的报文都鉴别报文的发送者。
- 实体鉴别是在系统接入的全部持续时间内对和自己通信的对方实体只需验证一次。

最简单的实体鉴别过程

- 可以使用共享的对称密钥实现实体鉴别。
- A 发送给 B 的报文的被加密，使用的是对称密钥 K_{AB} 。
- B 收到此报文后，用共享对称密钥 K_{AB} 进行解密，从而鉴别了实体 A 的身份。该密钥只有 A 和 B 知道。



重放攻击

- 重放攻击 (replay attack)

- 入侵者 C 可以从网络上截获 A 发给 B 的报文。
- C 并不需要破译这个报文，而是直接把这个截获的、由 A 加密的报文发送给 B，使 B 误认为 C 就是 A。然后 B 就向伪装是 A 的 C 发送应发给 A 的报文。

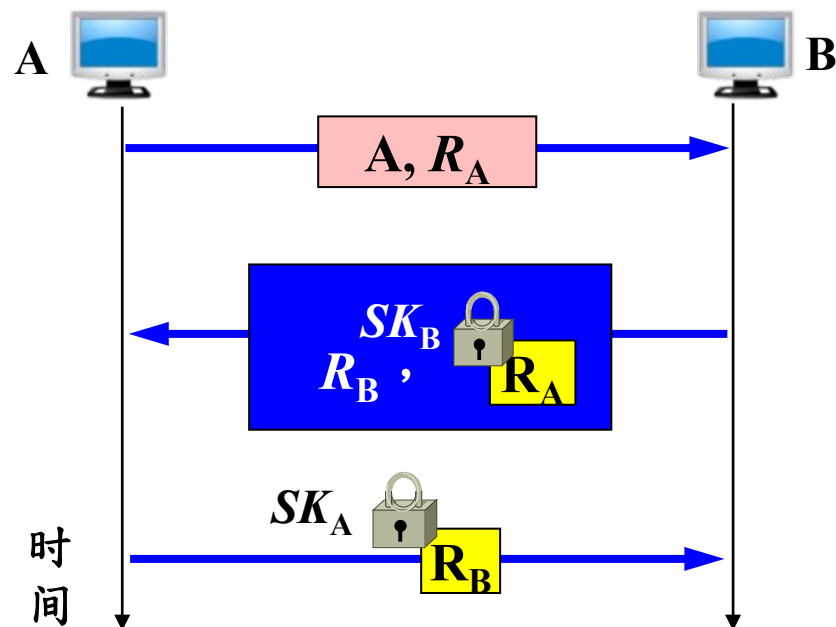
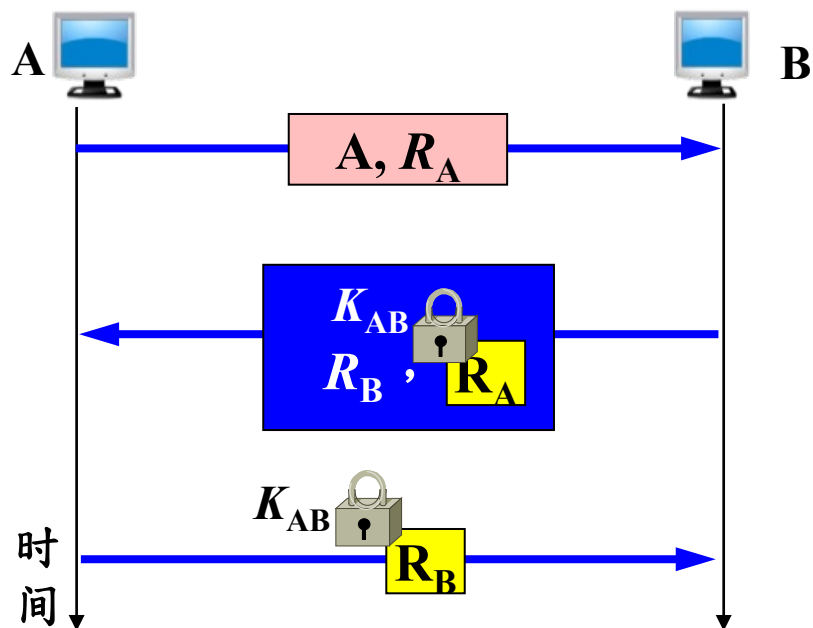
- IP 欺骗

- C 甚至还可以截获 A 的 IP 地址，然后把 A 的 IP 地址冒充为自己的 IP 地址，使 B 更加容易受骗。

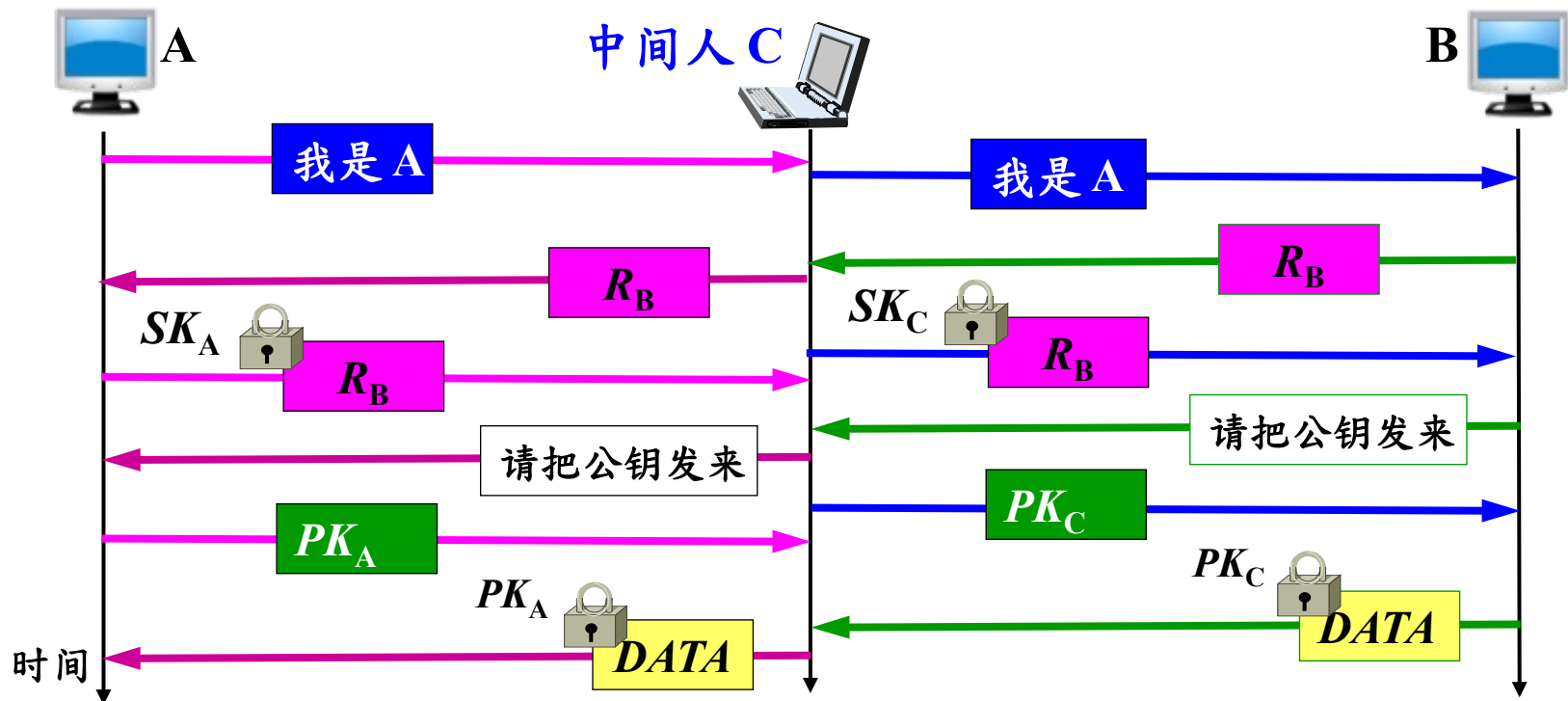
使用不重数进行鉴别

- 不重数 (nonce)

- 一个不重复使用的大随机数，即“一次一数”。
- 重放攻击时无法重复使用所截获的不重数。



中间人攻击



由此可见，公钥的分配以及认证公钥的真实性也是一个非常重要的问题。

内容纲要

	3	数字签名
	4	鉴别
	5	密钥分配
	6	互联网使用的安全协议
	7	系统安全：防火墙与入侵检测

密钥分配

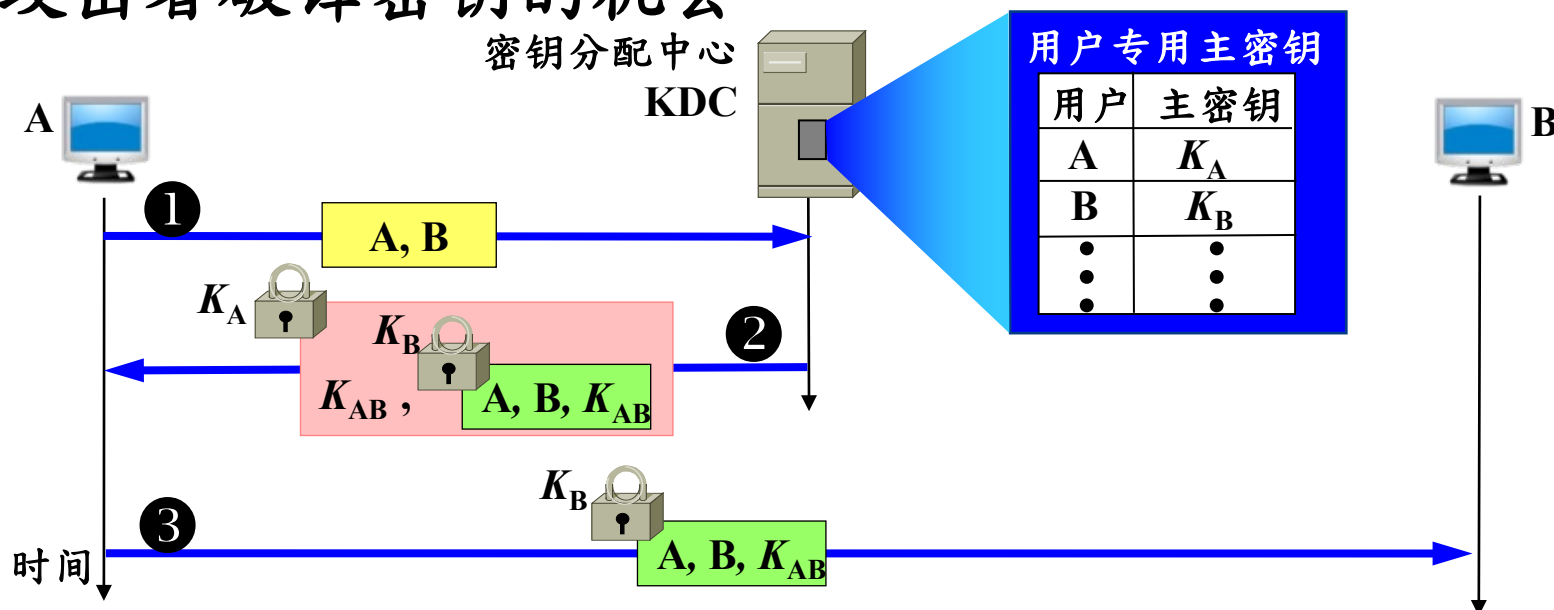
- 密钥管理：密钥的产生、分配、注入、验证和使用
 - 本节只讨论 密钥的分配。
 - 密码算法是公开的，网络安全性完全基于密钥安全保护上。
 - 密钥分配是密钥管理中最大的问题。
- 密钥必须通过最安全的通路进行分配。
 - 网外分配方式：派非常可靠的信使携带密钥分配给互相通信的各用户。
 - 网内分配方式：密钥自动分配。

对称密钥的分配

- 目前常用的密钥分配方式是设立密钥分配中心 KDC (Key Distribution Center)。
- KDC 是大家都信任的机构，其任务就是给需要进行秘密通信的用户临时分配一个会话密钥（仅用一次）。
- 假设用户 A 和 B 都是 KDC 的登记用户，并已经在 KDC 的服务器上安装了各自和 KDC 进行通信的主密钥（master key） K_A 和 K_B 。
 - “主密钥”可简称为“密钥”。

对称密钥的分配

- 为防止重放攻击，KDC 还可在报文中加入时间戳。
- 会话密钥 K_{AB} 是一次性的，因此保密性较高。
- KDC 分配给用户的密钥 K_A 和 K_B ，应定期更换，以减少攻击者破译密钥的机会。



Kerberos

- 目前最出名的密钥分配协议是 Kerberos V5。
- Kerberos 既是鉴别协议，同时也是 KDC，它已经变得很普及，现在是互联网建议标准。
- Kerberos 使用比 DES 更加安全的高级加密标准 AES 进行加密。

公钥的分配

- 在公钥密码体制中，如果每个用户都具有其他用户的公钥，就可实现安全通信。
- 但不能随意公布用户的公钥，因为无法防止假冒和欺骗。使用者也无法确定公钥的真正拥有者。

公钥的分配

- 需要有一个值得信赖的机构——即认证中心 CA (Certification Authority)，来将公钥与其对应的实体（人或机器）进行绑定(binding)。
- 认证中心一般由政府出资建立。
- 每个实体都有 CA 发来的证书 (certificate)，里面有公钥及其拥有者的标识信息。
- 此证书被 CA 进行了数字签名，是不可伪造的，可以信任。
- 证书是一种身份证明，用于解决信任问题。

CA 证书

- 任何用户都可从可信的地方（如代表政府的报纸）获得认证中心 CA 的公钥，此公钥用来验证某个公钥是否为某个实体所拥有（通过向 CA 查询）。
- 有的大公司也提供认证中心服务。
- CA 证书具有统一的格式，ITU-T 制定了 X.509 协议标准，用来描述证书的结构。
- IETF 接受了 X.509，仅做了少量的改动，给出了互联网 X.509 公钥基础结构 PKI (Public Key Infrastructure)。

CA 证书

- CA 证书不是永久有效，它可以过期，也可以被吊销。
- 有很多原因导致证书被吊销，例如：
 - 用户的私钥已被泄漏
 - 该用户不再被该 CA 认证
 - CA 签署用户证书的私钥已被泄漏
- CA 建立并维护一个证书吊销列表。

内容纲要

	3	数字签名
	4	鉴别
	5	密钥分配
	6	互联网使用的安全协议
	7	系统安全：防火墙与入侵检测

网络层安全协议

- IP 安全性很差：

- 没有为通信提供良好的数据源鉴别机制；
- 没有为数据提供强大的完整性保护机制；
- 没有为数据提供任何机密性保护；
- 在设计和实现上存在安全漏洞，使各种攻击有机可乘。例如：攻击者很容易构造一个包含虚假地址的 IP 数据报。

网络层安全协议

- IP 几乎不具备任何安全性，不能保证：
 - 数据机密性
 - 数据完整性
 - 数据来源认证
- 由于其在设计和实现上存在安全漏洞，使各种攻击有机可乘。例如：攻击者很容易构造一个包含虚假地址的 IP 数据报。
- IPsec 提供了标准、健壮且包含广泛的机制保证 IP 层安全。

IPsec 协议

- IPsec 就是 “IP 安全 (security)” 的缩写。
- IPsec 是个框架
 - IPSec是能够在 IP 层提供互联网通信安全的协议族。
 - 它允许通信双方选择合适的算法和参数（如：密钥长度）。
- 为保证互操作性，IPsec 还包含了所有 IPsec 的实现都必须有的一套加密算法。
- IPSec 支持 IPv4 和 IPv6。

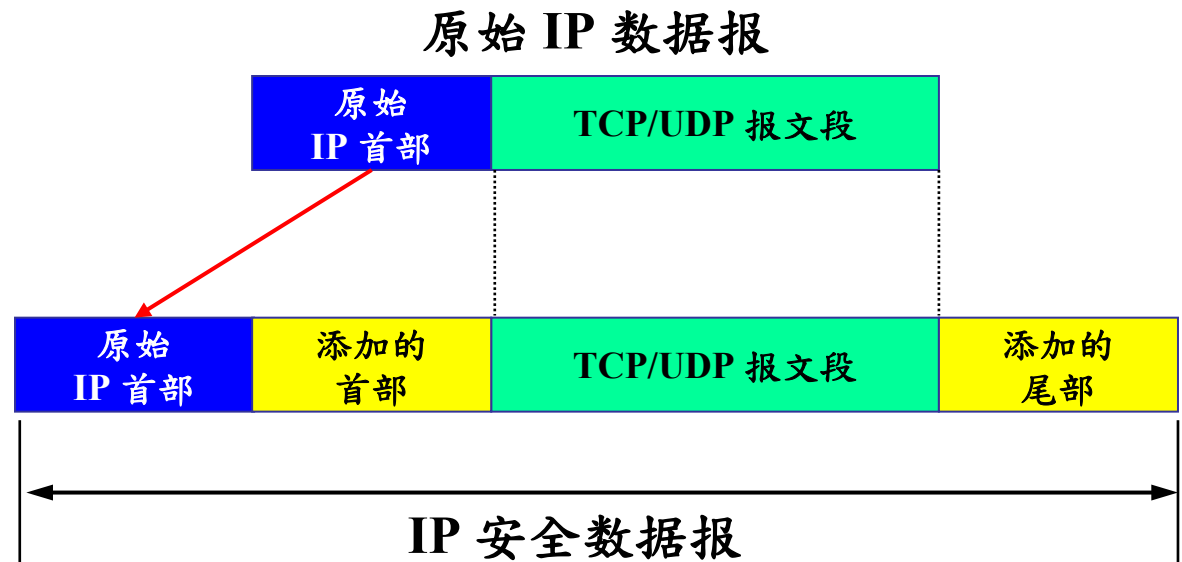
IPsec 协议

- IPsec 由三部分组成
 - IP 安全数据报格式的两个协议
 - 鉴别首部 AH (Authentication Header) 协议：提供源点鉴别和数据完整性，但不能保密。
 - 封装安全有效载荷 ESP (Encapsulation Security Payload) 协议：比 AH 协议复杂得多，它提供源点鉴别、数据完整性和保密。
 - AH 协议的功能都已包含在 ESP 协议中。
 - 有关加密算法的三个协议（在此不讨论）
 - 互联网密钥交换 IKE (Internet Key Exchange) 协议
- 使用 ESP 或 AH 协议的 IP 数据报称为 IPsec 数据报。

IP 安全数据报的工作方式

- 运输方式 (transport mode)

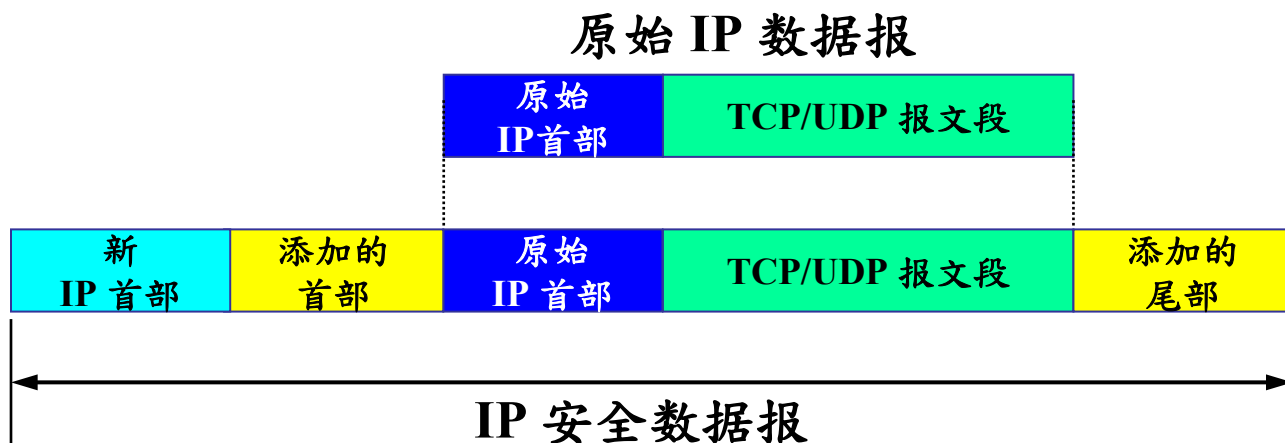
- 在整个运输层报文段的前后分别添加若干控制信息适合于主机到主机之间的安全传送。
- 需要使用 IPsec 的主机都运行 IPsec 协议。



IP 安全数据报的工作方式

- 隧道方式 (tunnel mode)

- 在原始的 IP 数据报的前后分别添加若干控制信息，再加上新的 IP 首部，构成一个 IP 安全数据报。
- 需要在 IPsec 数据报所经过的所有路由器都运行 IPsec 协议。
- 隧道方式常用来实现虚拟专用网 VPN。



IP 安全数据报的工作方式

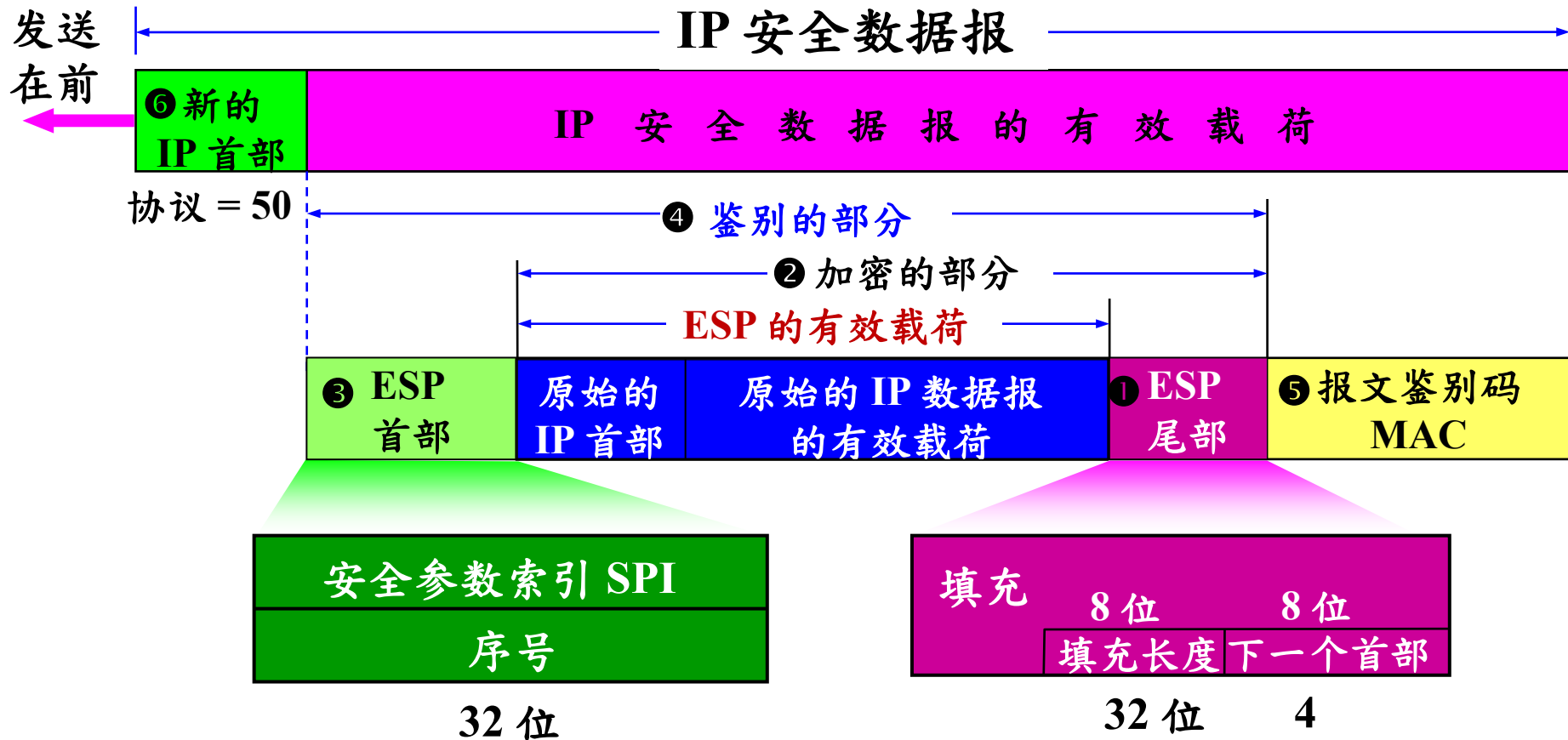
- 无论使用哪种方式，最后得出的 IP 安全数据报的 IP 首部都是不加密的。
- 所谓“安全数据报”是指数据报的数据部分是经过加密的，并能够被鉴别的。
- 通常把数据报的数据部分称为数据报的有效载荷(payload)。

安全关联 SA

- 在发送 IPSec 数据报之前，在源实体和目的实体之间必须创建一条网络层的逻辑连接，即安全关联。
- IPsec 把传统无连接的网络层转为具有逻辑连接的。
- 安全关联的特点
 - 安全关联是从源点到终点的单向连接，它能提供安全服务。
 - 在安全关联 SA 上传送的就是 IP 安全数据报。
 - 如要进行双向安全通信，则两个方向都需要建立安全关联。
 - 若 n 个员工进行双向安全通信，一共需要创建 $(2 + 2n)$ 条安全关联 SA。

IP 安全数据报的格式

• 隧道方式下的 IP 安全数据报的格式



IP 安全数据报的格式

- 注意：

- 在“原始的 IP 首部”中，用主机 H1 和 H2 的 IP 地址分别作为源地址和目的地址。
- 而在 IP 安全数据报的“新的 IP 首部”中，用路由器 R1 和 R2 的 IP 地址分别作为源地址和目的地址。

IPSec 的其他构件

- 安全关联数据库 SAD (Security Association Database)
 - 存放SA。
- 安全策略数据库 SPD (Security Policy Database)
 - 指明什么样的数据报需要进行 IPsec 处理。
- 互联网密钥交换 IKE (Internet Key Exchange)
 - 为 IP 安全数据报创建安全关联 SA。

互联网密钥交换 IKE

- IKE 是个非常复杂的协议，在 2014 年 10 月已成为互联网的正式标准 [RFC 7296]。
- 以另外三个协议为基础：
 - Oakley 是密钥生成协议 [RFC 2412]。
 - 安全密钥交换机制 SKEME 是用于密钥交换的协议。它利用公钥加密来实现密钥交换协议中的实体鉴别。
 - 互联网安全关联和密钥管理协议 ISAKMP 用于实现IKE中定义的密钥交换，使IKE的交换能够以标准化、格式化的报文创建安全关联 SA。

运输层安全协议

- 安全套接字层 SSL (Secure Socket Layer)

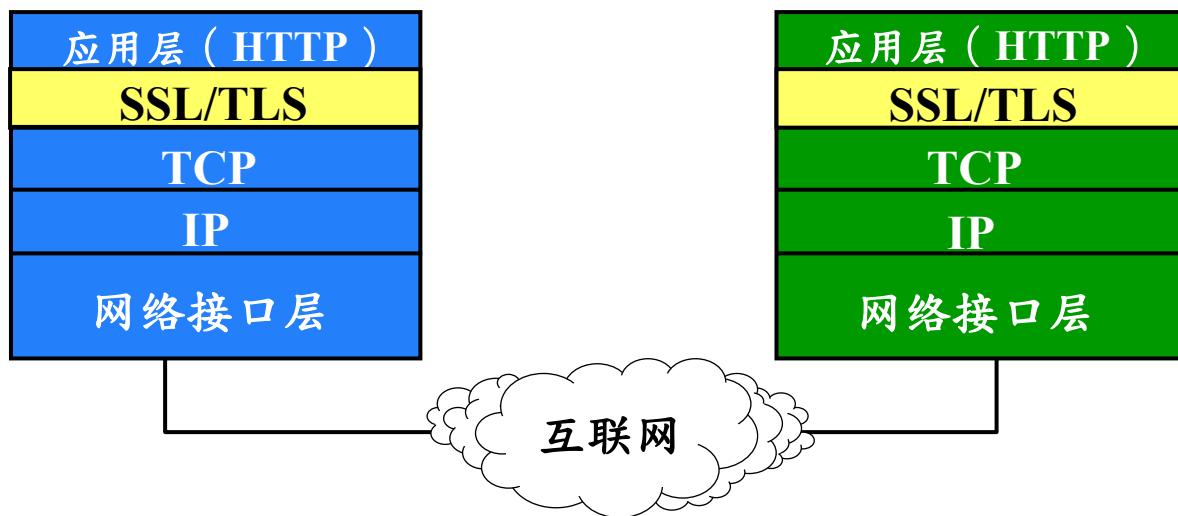
- 安全套接层 SSL 由 Netscape 于 1994 年开发，广泛应用于基于万维网的各种网络应用（但不限于万维网应用）。
- SSL 作用在端系统应用层的 HTTP 和运输层之间，在 TCP 之上建立起一个安全通道，为通过 TCP 传输的应用层数据提供安全保障。
- 1996 年发布 SSL 3.0，成为 Web 安全的事实标准。

- 运输层安全 TLS (Transport Layer Security)

- 1999 年，IETF 在 SSL 3.0 基础上推出了传输层安全标准 TLS，为所有基于 TCP 的网络应用提供安全数据传输服务。

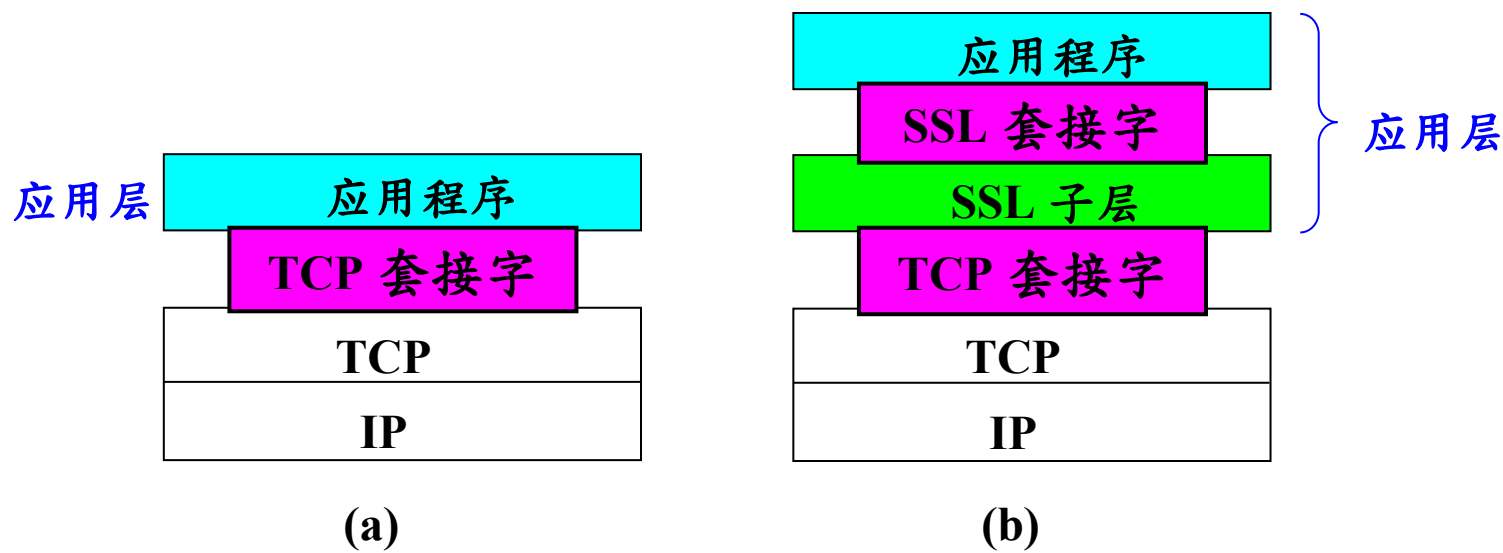
SSL / TLS 的位置

- 在发送方，SSL 接收应用层的数据，对数据进行加密，然后把加了密的数据送往 TCP 套接字。在接收方，SSL 从 TCP 套接字读取数据，解密后把数据交给应用层。



SSL / TLS 的位置

- 建立在可靠的 TCP 之上，与应用层协议独立无关。
- 被所有常用的浏览器和万维网服务器所支持。
- 基本目标：实现两个应用实体之间的安全可靠通信。



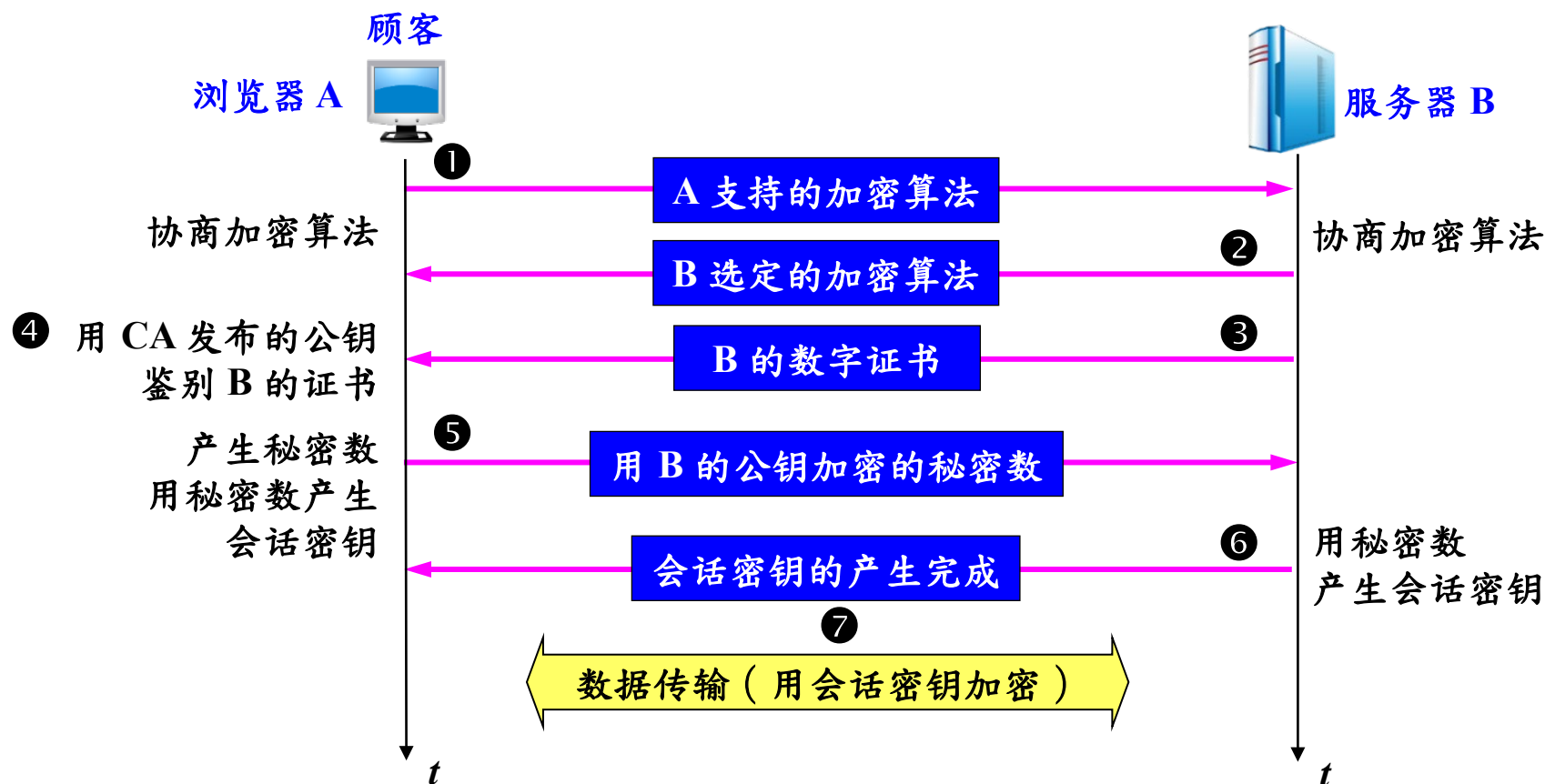
SSL / TLS

- 应用层使用 SSL 最多的就是 HTTP，但 SSL 并非仅用于 HTTP，而是可用于任何应用层的协议。
- 应用程序 HTTP 调用 SSL 对整个网页进行加密时，网页上会提示用户，在网址栏原来显示 http 的地方，现在变成了 https。在 http 后面加上的 s 代表 security，表明现在使用的是提供安全服务的 HTTP 协议（TCP 的 HTTPS 端口号是 443，而不是平时使用的端口号 80）。

SSL 提供的安全服务

- SSL 服务器鉴别，允许用户证实服务器的身份。支持 SSL 的客户端通过验证来自服务器的证书，来鉴别服务器的真实身份并获得服务器的公钥。
- SSL 客户鉴别，SSL 的可选安全服务，允许服务器证实客户的身份。
- 加密的 SSL 会话，对客户和服务端间发送的所有报文进行加密，并检测报文是否被篡改。

SSL 提供的安全服务



SSL 安全会话建立过程

- 协商加密算法。
 - ① 浏览器 A 向服务器 B 发送浏览器的 SSL 版本号和一些可选的加密算法。
 - ② B 从中选定自己所支持的算法（如 RSA），并告知 A。
- 服务器鉴别。
 - ③ 服务器 B 向浏览器 A 发送包含其 RSA 公钥的数字证书。
 - ④ A 使用该证书的认证机构 CA 公开发布的 RSA 公钥对该证书进行验证。

SSL 安全会话建立过程

- 会话密钥计算。
 - 由浏览器 A 随机产生一个秘密数。
 - ⑤ 用服务器 B 的 RSA 公钥进行加密后发送给 B。
 - ⑥ 双方根据协商的算法产生共享的对称会话密钥。
- 安全数据传输。
 - ⑦ 双方用会话密钥加密和解密它们之间传送的数据并验证其完整性。

PGP (Pretty Good Privacy)

- 电子邮件安全协议就应当为每种加密操作定义相应的算法，以及密钥管理、鉴别、完整性保护等方法。
- PGP (Pretty Good Privacy) 是一个完整的电子邮件安全软件包，包括加密、鉴别、电子签名和压缩等技术。
- PGP 并没有使用什么新的概念，它只是将现有的一些算法如 MD5，RSA，以及 IDEA 等综合在一起而已。
- 虽然 PGP 已被广泛使用，但 PGP 并不是互联网的正式标准。

内容纲要

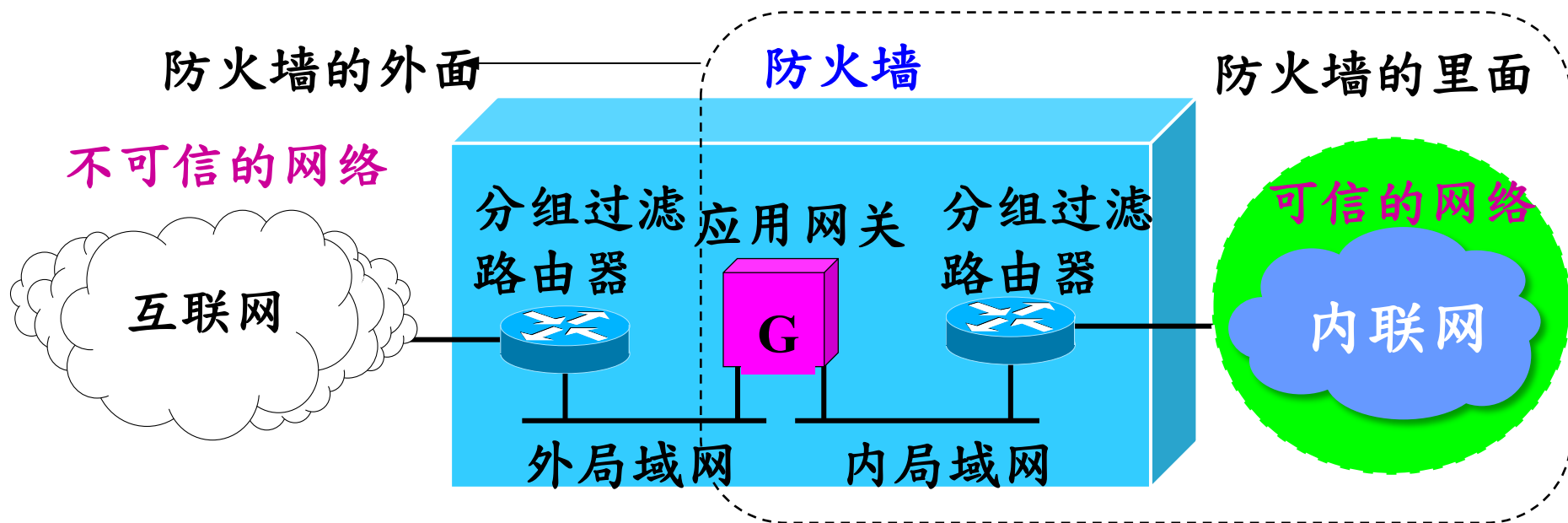
	3	数字签名
	4	鉴别
	5	密钥分配
	6	互联网使用的安全协议
	7	系统安全：防火墙与入侵检测

防火墙

- 防火墙是由软件、硬件构成的系统，是一种特殊编程的路由器，用来在两个网络之间实施访问控制策略。
- 访问控制策略是由使用防火墙的单位自行制订的，为的是可以最适合本单位的需要。
- 防火墙内的网络称为“可信的网络”(trusted network)，而将外部的互联网称为“不可信的网络”(untrusted network)。
- 防火墙可用来解决内联网和外联网的安全问题。

防火墙

- 防火墙在互连网络中的位置



防火墙的功能

- 防火墙的功能有两个：阻止和允许。
- “阻止”就是阻止某种类型的通信量通过防火墙（从外部网络到内部网络，或反过来）。
- “允许”的功能与“阻止”恰好相反。
- 防火墙必须能够识别各种类型的通信量。不过在大多数情况下防火墙的主要功能是“阻止”。

防火墙技术

- 分组过滤路由器是一种具有分组过滤功能的路由器
 - 根据过滤规则对进出内部网络的分组执行转发或者丢弃（即过滤）。
 - 过滤规则基于分组的网络层或运输层首部的信息
 - 如：源/目的 IP 地址、源/目的端口、协议类型（TCP 或 UDP）等。
- 分组过滤可以是无状态的，即独立地处理每一个分组。
- 也可以是有状态的，即要跟踪每个连接或会话的通信状态，并根据这些状态信息来决定是否转发分组。
- 简单高效，对用户透明，但不能对高层数据进行过滤。

防火墙技术

- 应用网关也称为代理服务器 (proxy server)
 - 它在应用层通信中扮演报文中继的角色。
 - 每种网络应用需要一个应用网关。
 - 在应用网关中，可以实现基于应用层数据的过滤和高层用户鉴别。
 - 所有进出网络的应用程序报文都必须通过应用网关。
 - 应用网关也有一些缺点：
 - 每种应用都需要一个不同的应用网关。
 - 在应用层转发和处理报文，处理负担较重。
 - 对应用程序不透明，需要在应用程序客户端配置应用网关地址。

入侵检测系统

- 防火墙试图在入侵行为发生之前阻止所有可疑的通信。
- 入侵检测系统 IDS (Intrusion Detection System) 能够在入侵已经开始，但还没有造成危害或在造成更大危害前，及时检测到入侵，以便尽快阻止入侵，把危害降低到最小。
 - IDS 对进入网络的分组执行深度分组检查，当观察到可疑分组时，向网络管理员发出告警或执行阻断操作（由于 IDS 的“误报”率通常较高，多数情况不执行自动阻断）。
 - IDS 能用于检测多种网络攻击，包括网络映射、端口扫描、DoS 攻击、蠕虫和病毒、系统漏洞攻击等。

入侵检测系统

- 基于特征的 IDS

- 维护一个所有已知攻击标志性特征的数据库。

- 这些特征和规则通常由网络安全专家生成，由网络管理员定制加入只能检测已知攻击，对于未知攻击则束手无策。

- 基于异常的 IDS

- 通过观察正常运行的网络流量，学习正常流量的统计特性和规律。当检测到网络中流量某种统计规律不符合正常情况时，则认为可能发生了入侵行为。

- 大多数部署的 IDS 主要是基于特征的，尽管某些 IDS 包括了某些基于异常的特性。

谢谢观看



廈門大學
XIAMEN UNIVERSITY



信息学院 黄 焯
(特色化示范性软件学院) 博士, 副教授
School of Informatics Wei Huang